Title: Web Application Penetration Testing and Incident Response Report

1. Executive Summary

This project demonstrates web application security testing in a controlled lab using Kali Linux, DVWA, and Burp Suite. The objective is to identify common vulnerabilities, document test results, and recommend appropriate security controls.

2. Objectives

- Identify common web application vulnerabilities.
- Perform controlled security tests.
- Analyze results and recommend mitigations.
- Understand the incident response process.

3. Tools Used

- Kali Linux
- DVWA
- Burp Suite Community Edition
- Nmap
- curl

4. Methodology

1. Reconnaissance and information gathering.
2. Vulnerability identification.
3. Controlled testing of selected vulnerabilities.
4. Evidence collection and analysis.
5. Mitigation recommendations.

5. Findings

- **SQL Injection:** A controlled test demonstrated that unsafe input could return multiple database records. Prepared statements were tested as a mitigation.
- **Cross-Site Scripting:** Stored, reflected, and DOM-based XSS test payloads triggered browser alerts in DVWA.
- **Cross-Site Request Forgery:** A password-change request demonstrated the risk of state-changing requests without adequate CSRF protection.
- **File Inclusion:** A local file disclosure attempt was unsuccessful.

- **Burp Suite:** HTTP requests and responses were inspected using Proxy and HTTP history.
- **Security Headers:** Response headers were inspected using curl. Several commonly recommended security headers were not observed in the inspected response.

6. Incident Response Plan

- **Identification:** Detect and verify suspicious activity.
- **Containment:** Isolate affected systems or restrict access.
- **Eradication:** Remove the cause of the incident.
- **Recovery:** Restore systems and verify normal operation.
- **Lessons Learned:** Document the incident and improve security controls.

7. Mitigation Recommendations

- Use parameterized SQL queries.
- Apply context-aware output encoding to prevent XSS.
- Implement and validate CSRF tokens.
- Restrict file inclusion to approved paths.
- Configure suitable HTTP security headers.
- Monitor logs and investigate suspicious requests.

8. Conclusion

The project provided practical experience in web application security testing and vulnerability mitigation. Testing was limited to a controlled local lab, and unsuccessful or incomplete tests should not be considered confirmed vulnerabilities.

9. Evidence

Practical screenshots are maintained in the project's Evidence folder.